

Phishing Email Detection & Awareness Report

1. Introduction

This report presents a professional analysis of a phishing email campaign targeting Netflix users. The purpose of this assessment is to identify clear phishing indicators, evaluate the associated business risks, and recommend effective remediation strategies to mitigate similar cyber threats.

Phishing remains one of the most common and successful cyberattack techniques, primarily due to its reliance on social engineering and human error. This case study demonstrates how attackers exploit trust and urgency to deceive users into disclosing sensitive information.

2. Case Study Overview: Netflix Phishing Scam

The analyzed email impersonates Netflix Support, claiming that the recipient's account has been placed on hold due to a payment issue. The email urges the user to verify payment information immediately by clicking a provided link.

The objective of this analysis is to determine whether the email is legitimate or malicious using standard email investigation techniques.

3. Security Classification & Threat Profile

Classification:

Classification: Phishing / Malicious Email

Threat Type: Credential Harvesting & Financial Fraud

Risk Level: High

Attack Vector: Email-Based Social Engineering

Potential Impact

If successful, the attack may lead to:

Theft of user login credentials

Credit card fraud

Account takeover

Identity theft

Unauthorized financial transactions

This type of phishing attack primarily targets confidential information, which can then be exploited or sold on the dark web.

4. Technical Findings & Security Analysis

A detailed technical assessment identified multiple phishing indicators:

4.1 Sender Address Analysis

The email originated from info@confirm.com, which does not match Netflix's official domain (@netflix.com).

Legitimate emails from Netflix are always sent from verified corporate domains.

4.2 Email Header Inspection

Using an Email Header Analyzer, the message failed the SPF (Sender Policy Framework) authentication check.

This confirms that the sender was not authorized to send emails on behalf of Netflix, indicating domain spoofing.

4.3 Linguistic & Grammar Red Flags

The email contained grammatical errors such as:

"We have placed your account on hold"

Poor grammar and unnatural phrasing are common characteristics of phishing emails.

4.4 URL & Link Inspection

Using Browser Developer Tools, the embedded hyperlink redirected to:

u2733794.ct.sendgrid.net/...

Instead of directing users to an official Netflix domain, the link redirected to a suspicious third-party domain. This is a strong indicator of credential harvesting.

5. Business Risk Analysis

Phishing attacks pose significant risks not only to individuals but also to organizations. If such an attack succeeds, potential consequences include:

Financial losses from fraudulent transactions

Exposure of sensitive customer data

Reputational damage

Loss of customer trust

Increased incident response and recovery costs

Potential regulatory and compliance violations

Beyond immediate financial impact, phishing incidents can severely damage an organization's brand credibility and long-term customer relationships.

6. Remediation & Best Practices

6.1 Recommendations for Employees

Employees play a critical role in preventing phishing attacks. The following best practices should be followed:

Verify the Sender: Always check the full email address, not just the display name.

Hover Before Clicking: Preview hyperlinks before clicking to verify the destination URL.

Be Cautious of Urgency: Treat emails demanding immediate action with suspicion.

Report Suspicious Emails: Use the "Report Phishing" feature or notify the IT department immediately.

Never Share Credentials: Legitimate companies will never request passwords or sensitive information via email.

6.2 Recommendations for the Organization

To strengthen organizational defenses, the following measures should be implemented:

Multi-Factor Authentication (MFA): Adds an additional layer of protection even if credentials are compromised.

Email Filtering & Anti-Spoofing Controls: Deploy secure email gateways to block suspicious domains.

SPF, DKIM, and DMARC Enforcement: Proper configuration prevents domain spoofing and improves email authentication.

Security Awareness Training: Conduct regular phishing simulations and cybersecurity training sessions.

Security Monitoring: SOC teams should actively monitor email logs and unusual login attempts.

A layered security approach combining technical controls and employee awareness significantly reduces phishing risks.

7. Tools & Methodology Used

The following tools and techniques were used during this analysis:

Email Header Analyzer

Browser Developer Tools

Public phishing sample

Microsoft Word / PDF

8. Skills Demonstrated

Phishing Email Analysis

Email Header Analysis

IOC Identification

Threat Classification

Social Engineering Detection

Risk Assessment

Security Awareness

Incident Reporting

Technical Documentation

9. Conclusion

This project demonstrates how phishing emails combine technical deception with social engineering to steal user credentials.

The investigation identified multiple phishing indicators, including spoofed sender information, failed email authentication, suspicious URLs, and psychological manipulation techniques.

Effective protection against phishing requires a combination of strong technical controls, secure email authentication, continuous monitoring, and regular cybersecurity awareness training.

Prepared by: Mohamed Dahir Mohamed